

TLP:CLEAR

ОТЧЁТ ОБ ИНЦИДЕНТЕ

Android-RAT CraxsRAT под видом приложения «Safe Russia» — шпионаж, кража SMS/OTP и удалённый контроль устройства

Android RAT • CraxsRAT (MaaS) • Banker • Dropper • Accessibility Abuse

Параметр	Значение
Дата отчёта	23 июля 2026
Объект	Safe_Russia.apk (двухстадийный дроппер + CraxsRAT)
Классификация	Android RAT / Spyware / Banker (многоступенчатый дроппер)
Уровень угрозы	ВЫСОКИЙ
Семейство / MaaS	CraxsRAT (Malware-as-a-Service; разработка связывается с актором EVLF)
Прицел	Русскоязычная аудитория; доставка через угнанные Telegram-аккаунты

1. Краткое заключение

Проанализирован Android-сэмпл «Safe_Russia.apk», маскирующийся под приложение безопасности/VPN «Safe Russia». Файл вредоносный: это двухстадийный дроппер, доставляющий коммерческий троян удалённого доступа (RAT) CraxsRAT. Распространяется через угнанные Telegram-аккаунты, прицел — русскоязычная аудитория.

Внешнее приложение — тонкий загрузчик (запрашивает лишь право устанавливать приложения). Внутри зашифрован (XOR, ключ 0x5A) второй APK — сам CraxsRAT (пакет com.veloxapp.speedcore), который дроппер уговаривает пользователя доустановить через системный установщик. После включения службы «Специальных возможностей» (Accessibility) зловред получает почти полный контроль над устройством: кейлоггинг и чтение экрана, перехват SMS и уведомлений (кража одноразовых кодов/ОТР → банковское мошенничество), overlay-фишинг, запись экрана/микрофона/камеры, доступ к геолокации, контактам и файлам, самозащита от удаления.

CraxsRAT — покупной инструмент (Malware-as-a-Service), поэтому атрибуция к конкретному лицу/группе по сэмплу невозможна. Обоснованный профиль — русскоязычный финансово-мотивированный оператор, использующий тему безопасности/VPN и связанную соц-инженерию вокруг мессенджера MAX и «голосования».

2. Объект анализа

Параметр	Значение
Имя файла	Safe_Russia.apk
Размер	6 750 966 байт (6.4 МБ)
SHA-256 (стадия 1, дроппер)	5f94e59c132a7ed0e35b60146d973a728ab9f390c8291f9547cee26c56427738
SHA-256 (стадия 2, CraxsRAT)	fc99609172910a8fad9522b374f8bae21e5805abdf052a49029edb53620a8e8c
Пакет (стадия 1)	com.uisy.cache.installertest
Пакет (стадия 2)	com.veloxapp.speedcore
Отображаемое имя	Safe Russia (кириллические гомоглифы s, i)
Дата сборки (стадия 2)	versionCode 2026070301 (2026-07-03)

3. Цепочка атаки (Kill Chain)

#	Этап	Описание
1	Социальная инженерия	Жертве через угнанные Telegram-аккаунты присылают «Safe Russia.apk» под видом приложения безопасности/VPN.
2	Установка дроппера	Пользователь ставит внешний APK — тонкий загрузчик (единственное значимое право: REQUEST_INSTALL_PACKAGES). Маскировка под VPN.
3	Распаковка	Дроппер расшифровывает встроенный APK методом XOR (ключ 0x5A) →

	payload	валидный APK стадии 2.
4	Установка зловреда	Через PackageManager Session API устанавливается com.veloxapp.speedcore (соц-инженерная доустановка).
5	Активация Accessibility	Пользователя убеждают включить «Специальные возможности». После этого RAT авто-выдаёт себе права, читает экран, эмулирует нажатия.
6	Закрепление	Foreground-сервисы, автозапуск при загрузке, запрос игнорировать оптимизацию батареи, обход менеджеров автозапуска OEM.
7	Связь с C2	Постоянный TCP-сокеты к управляющему серверу на нестандартном порту: стриминг экрана/звука, выгрузка списка приложений, приём команд.
8	Кража и слежка	Перехват SMS (priority 999) и уведомлений → OTP-коды; overlay-фишинг; запись экрана/микрофона/камеры; геолокация, контакты, файлы.

4. Технический разбор

4.1. Стадия 1 — дроппер (com.uisy.cache.installertest)

- Отображаемое имя «Safe Russia» использует кириллические гомоглифы (s U+0455, i U+0456) — визуально неотличимо от «Safe Russia».
- Единственное значимое право — REQUEST_INSTALL_PACKAGES: классический тонкий инсталлятор.
- Несёт зашифрованный payload (7.76 МБ), XOR-ключ 0x5A → APK стадии 2. Установка через PackageManager Session API.
- Маскировка под VPN: сервис-«VPN», легенда «Safe Russia = безопасный VPN».
- Анти-анализ: у entry classes.dex в ZIP обнулён CRC-32 (00000000) — unzip/apktool извлекают 0 байт, тогда как Android и androguard читают dex нормально. Простой сигнатурный признак для детекта.

4.2. Стадия 2 — CraxsRAT (com.veloxapp.speedcore)

- Ядро — AccessibilityService (label «Safe Russia», capabilities=169: чтение содержимого окон + жесты): кейлоггинг, авто-выдача прав, авто-клик.
- NotificationListener «Notification Reader» — кража содержимого уведомлений (в т.ч. OTP-коды).
- SMS-receiver с priority 999 + права SEND/READ/RECEIVE_SMS — перехват входящих SMS (банковские коды), скрытая отправка.
- Overlay-фишинг (SYSTEM_ALERT_WINDOW); зашитая цель — messenger.com.
- Шпионаж: запись экрана (MediaProjection), камера, микрофон, геолокация, контакты, доступ к хранилищу, звонки, WRITE_SECURE_SETTINGS.
- Персистентность: boot-ресиверы под OEM (Xiaomi/Huawei/Oppo/Vivo/Meizu/Smartisan); евазия — <queries> по security/battery-менеджерам вендоров.
- Крипта: BouncyCastle (обфускация конфига/трафика). Транспорт C2 — сырой TCP-сокеты (+ опц. TLS), авто-реконнект, стриминг.

5. Индикаторы компрометации (IOC)

Тип	Значение
SHA-256 (дроппер)	5f94e59c132a7ed0e35b60146d973a728ab9f390c8291f9547cee26c56427738

SHA-256 (CraxsRAT)	fc99609172910a8fad9522b374f8bae21e5805abdf052a49029edb53620a8e8c
MD5 (дроппер)	541e1d211a172b9353e347e292f34555
Пакет (стадия 1)	com.uisy.cache.installertest
Пакет (стадия 2)	com.veloxapp.speedcore
Домен (фишинг MAX)	golosovanie-v-maxe[.]digital
Домен (фишинг MAX)	maxnost-golos[.]lol
Домен (фишинг MAX)	maxmab[.]lol

Примечание: часть сетевых индикаторов (управляющий сервер и связанная инфраструктура) удержана в непубличной версии отчёта во избежание преждевременного оповещения оператора.

6. MITRE ATT&CK (Mobile)

Техника	ID
Masquerading / Deliver Malicious App	T1655 / T1660
Ingress Tool Transfer (двухстадийный дроппер)	T1644
Obfuscated/Encrypted Payload (XOR, обнулённый CRC)	T1406 / T1628
Abuse Accessibility Services	T1626 / T1517
Input Capture / Keylogging	T1417
SMS / OTP Interception	T1636.004 / T1582
Screen / Audio / Video Capture	T1513 / T1429 / T1512
Location Tracking / Contacts / Files	T1430 / T1636.003 / T1533
Boot Persistence	T1624.001
C2 over non-standard socket	T1571 / T1437

7. Рекомендации

- Пользователям: не устанавливать «VPN/безопасность» из Telegram-ссылок; просьба включить «Специальные возможности» для непонятого приложения — красный флаг.
- MDM/детект: не-системные пакеты с WRITE_SECURE_SETTINGS + включённой службой Accessibility; APK вне магазинов; SMS-receiver с priority 999.
- Правило детекта: APK, где entry classes.dex имеет CRC-32 = 0, и/или asset, декодируемый XOR 0x5A в валидный APK.
- Проверять приложения на злоупотребление службой «Специальные возможности» и доступом к SMS/уведомлениям.

TLP:CLEAR — Этот документ может распространяться без ограничений.